



Информационная безопасность и защита информации

Модели безопасности

Нестеров С.А.
каф. «Системный анализ
и управление»

Модели безопасности

Типы управления доступом:

- 1. дискреционное (избирательное);*
- 2. мандатное;*
- 3. ролевое.*



Дискреционное управление доступом (Discretionary Access Control)

Также может называться «избирательное» или «разграничительное» управление доступом.

- все субъекты и объекты должны быть идентифицированы;
- права доступа субъекта к объекту системы определяются на основании некоторого внешнего по отношению к системе правила.

Правило может описываться матрицей доступа (или доступов):

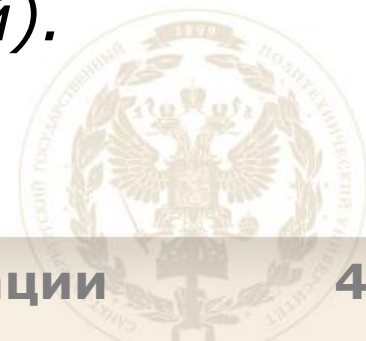
Пример матрицы доступа

	o ₁	o ₂	o ₃	o ₄
s ₁	rwe	∅	rw	rw
s ₂	e	rwe	r	∅

Дискреционное управление доступом

Варианты реализации:

- С объектом связывается список, содержащий перечень субъектов с указанием прав доступа. Подобные списки называются ACL – Access Control List, список управления доступом;*
- С каждым процессом (субъектом) связывается список доступных ему объектов с указанием разрешенных операций. Такой список называется Capability List, C-list (список возможностей).*



Мандатное управление доступом (Mandatory Access Control)

Также может называться «полномочное» или «принудительное» управление доступом.

- все субъекты и объекты должны быть идентифицированы;*
- задан линейно упорядоченный набор меток секретности;*
- каждому объекту системы присвоена метка секретности, определяющая ценность содержащейся в нем информации – его уровень секретности;*



Мандатное управление доступом

(продолжение)

- каждому субъекту системы присвоена метка секретности, определяющая уровень доверия к нему – его уровень доступа;*
- решение о разрешении доступа субъекта к объекту принимается исходя из типа доступа и сравнения метки субъекта и объекта.*



Ролевое управление доступом (Role-based Access Control)

- *Все сущности должны быть идентифицированы;*
- *Задано множество ролей, каждой из которых ставится в соответствие некоторое множество прав доступа к сущностям;*
- *Каждый субъект обладает некоторым множеством разрешенных (авторизованных) для данного субъекта ролей;*



Ролевое управление доступом (Role-based Access Control)

(продолжение)

- *Субъект обладает правом доступа к сущности, в случае когда он авторизован на роль, которой соответствует множество прав доступа, содержащее запрашиваемое право доступа к указанной сущности.*



Политика безопасности информационных потоков

Информационным потоком от сущности-источника к сущности-приемнику называется преобразование данных в сущности-приемнике. Реализуемое субъектами КС, зависящее от данных, содержащихся в сущности-источнике.

Информационный поток по памяти – информационный поток, при реализации которого фактор времени не является существенным.



Политика безопасности информационных потоков

Информационный поток по времени –

информационный поток, при реализации которого фактор времени является существенным (например, передача данных осуществляется путем изменения продолжительности интервалов времени между событиями в КС ли путем изменения последовательности событий в КС).



Политика безопасности информационных потоков

... основана а разделении всех информационных потоков в КС на множество разрешенных и множество запрещенных. Цель – обеспечить невозможность возникновения запрещённых информационных потоков.

Политика безопасности информационных потоков в большинстве случаев реализуется в сочетании с дискреционной, мандатной или ролевой политикой управления доступом.



Модель Харрисона-Рузо-Ульмана

Система описывается с помощью:

- множества объектов **O**;
- множества субъектов **S** ($S \subseteq O$);
- множества прав доступа **R**;
- матрицы доступа **M** (элемент матрицы далее обозначается $M[s,o]$).

	O1	O2
S1	{r,w,own}	{r}



Модель Харрисона-Рузо-Ульмана

Элементарные операции модели Харрисона-Рузо-Ульмана

Операция	Результат операции
«создать» субъект s' , где $s' \notin S$	$S' = S \cup \{s'\}; O' = O \cup \{s'\};$ $M'[s, o] = M[s, o]$ для всех $s \in S, o \in O;$ $M'[s', o] = \emptyset$ для всех $o \in O', M'[s, s'] = \emptyset$ для всех $s \in S'$
«создать» объект o' , где $o' \notin O$	$S' = S; O' = O \cup \{o'\};$ $M'[s, o] = M[s, o]$ для всех $s \in S, o \in O;$ $M'[s, o'] = \emptyset$ для всех $s \in S'$
«уничтожить» субъект s' , где $s' \in S$	$S' = S \setminus \{s'\}; O' = O \setminus \{s'\};$ $M'[s, o] = M[s, o]$ для всех $s \in S', o \in O';$
«уничтожить» объект o' , где $o' \in O$	$S' = S; O' = O \setminus \{o'\};$ $M'[s, o] = M[s, o]$ для всех $s \in S', o \in O';$
«внести» право $r' \in R$ в $M[s', o']$, где $s' \in S, o' \in O$	$S' = S; O' = O; M'[s, o] = M[s, o]$ для $s \neq s', s \in S',$ $o \neq o', o \in O';$ $M'[s', o'] = M[s', o'] \cup \{r'\}$
«удалить» право $r' \in R$ из $M[s', o']$, где $s' \in S, o' \in O$	$S' = S; O' = O; M'[s, o] = M[s, o]$ для $s \neq s', s \in S',$ $o \neq o', o \in O';$ $M'[s', o'] = M[s', o'] \setminus \{r'\}$

Модель Харрисона-Рузо-Ульмана

Общий формат команды

```
command C ( $x_1, \dots, x_k$ )  
if  $r_1 \in M[x_{s1}, x_{o1}]$  and ... and  $r_m \in M[x_{sm}, x_{om}]$   
  then  
     $a_1$ ;  
    ...  
     $a_n$ ;  
  endif  
end.
```



Модель Харрисона-Рузо-Ульмана

Пример 1.

command CreateFile(s, f)

«создать» объект *f*;

«внести» право владения *own* в $M[s, f]$;

«внести» право на чтение *read* в $M[s, f]$;

«внести» право на запись *write* в $M[s, f]$;

end.



Модель Харрисона-Рузо-Ульмана

Пример 2.

```
command GrantRead(s, s', f)
  if (own ∈ M[s,f]) then
    «внести» право на чтение read в M[s',f];
  endif
end.
```



Модель Харрисона-Рузо-Ульмана

Начальное состояние Q_0 называется *безопасным по отношению к некоторому праву r* , если невозможен переход системы в такое состояние Q , в котором может возникнуть утечка права r .

Для модели Харрисона-Рузо-Ульмана доказано :

1. существует алгоритм, который проверяет, является ли исходное состояние монооперационной системы безопасным для данного права r ;
2. задача проверки безопасности произвольных систем алгоритмически неразрешима.

Модель Белла-ЛаПадула

S – множество субъектов;

O – множество объектов;

L – линейно упорядоченное множество уровней безопасности;

$F: \mathbf{S} \cup \mathbf{O} \rightarrow \mathbf{L}$ – функция, определяющая уровень безопасности субъекта или объекта в данном состоянии;

V – множество состояний $(F, \mathbf{M})$;

M – матрица доступа.



Модель Белла-ЛаПадула

Состояние $(F, \mathbf{M})$ безопасно по чтению тогда и только тогда, когда для $\forall s \in \mathbf{S}, \forall o \in \mathbf{O}$ выполняется требование:

$$\text{чтение} \in M[s, o] \Rightarrow F(s) \geq F(o).$$

Состояние $(F, \mathbf{M})$ безопасно по записи тогда и только тогда, когда для $\forall s \in \mathbf{S}, \forall o \in \mathbf{O}$ выполняется требование:

$$\text{запись} \in M[s, o] \Rightarrow F(o) \geq F(s).$$



Модель Белла-ЛаПадула

Основная теорема безопасности для модели Белла – ЛаПадула.

Система $(v_0, \mathbf{R}, T)$ (т. е. система с начальным состоянием v_0 , множеством запросов $\mathbf{R}$, функцией переходов T) безопасна тогда и только тогда, когда состояние v_0 безопасно и функция переходов T такова, что для $\forall v \in \mathbf{V}$, достижимого из состояния v_0 после выполнения конечной последовательности запросов из $\mathbf{R}$ (таких что $T(v, r) = v^*$, где $v = (F, \mathbf{M})$ – исходное состояние, $v^* = (F^*, \mathbf{M}^*)$ – состояние после перехода), для $\forall s \in \mathbf{S}, \forall o \in \mathbf{O}$ выполняются следующие условия:

1. если чтение $\in M^*[s, o]$ и чтение $\notin M[s, o]$, то $F^*(s) \geq F^*(o)$;
2. если чтение $\in M[s, o]$ и $F^*(s) < F^*(o)$, то чтение $\notin M^*[s, o]$;
3. если запись $\in M^*[s, o]$ и запись $\notin M[s, o]$, то $F^*(o) \geq F^*(s)$;
4. если запись $\in M[s, o]$ и $F^*(o) < F^*(s)$, то запись $\notin M^*[s, o]$.



Модель Белла-ЛаПадула

Недостатки:

- 1. завышение уровня секретности;*
- 2. запись вслепую;*
- 3. проблема удаленного чтения-записи;*
- 4. проблема доверенных субъектов.*

